Rapport d'audit de sécurité Web

Rapport final - Mission J4 autonomie

Objectif : produire un audit de sécurité Web exploitable, traçable et compréhensible par un client.

Client	ACME Shop (instance de laboratoire OWASP Juice Shop)
Mission	Audit de sécurité Web - J4 autonomie
Période	10-11 Septembre 2026
Auditeurs	ZEQO Ermal
Version	1.0
Classification	Pédagogique / Confidentiel lab

Consigne : privilégiez un rapport court et défendable. N'ajoutez pas un constat non confirmé pour augmenter artificiellement le nombre de vulnérabilités.

1. Résumé exécutif

Cette section doit être compréhensible sans connaissance technique détaillée. Elle répond à : « Quel est le niveau de sécurité observé, pourquoi, et que faut-il traiter en premier ? »

Niveau global	☐ Bon ☐ Satisfaisant ☒ À renforcer ☐ Insuffisant
Justification en 3–5 lignes	L'audit a identifié trois faiblesses confirmées touchant principalement le contrôle d'accès et l'exposition de données. Un utilisateur peut agir sur le panier d'un autre compte, tandis que des ressources sensibles ou confidentielles sont accessibles depuis l'application.
Risque principal	Contrôles d'accès insuffisants et exposition de données sensibles/confidentielles.
Priorité immédiate	P1 : corriger le contrôle d'accès sur les paniers et traiter l'exposition des données d'authentification.

1.1 Problématiques générales

Domaine	Niveau observé	Problématique générale	Priorité
Authentification / session	Moyen	Aucun contournement d'authentification confirmé dans les tests documentés.	P3
Contrôle d'accès	Faible	Contrôle d'accès horizontal insuffisant : un utilisateur peut modifier le panier d'un autre compte.	P1
Validation des entrées	Moyen	La validation de certains champs est permissive, sans vulnérabilité de sécurité confirmée sur ce point.	P3
API / logique métier	Faible	Faiblesse de logique métier et d'autorisation au niveau des endpoints de panier.	P1
Configuration / exposition	Faible	Des ressources GitHub et FTP contenant des informations sensibles/confidentielles sont accessibles depuis l'application.	P1

Important : le niveau global ne doit pas être une moyenne mécanique des scores CVSS. Justifiez-le par les faiblesses observées, leur caractère systémique, l'exposition et le contexte de la mission.

1.2 Synthèse des constats

ID	Constat	Sévérité	CVSS	Priorité	Complexité
F-01	Exposition d'informations sensibles dans un dépôt accessible	Élevée	À confirmer	P1	M
F-02	Accès à un document confidentiel via /ftp	Moyenne	À confirmer	P2	F
F-03	Modification du panier d'un autre utilisateur	Élevée	À confirmer	P1	M

2. Contexte, périmètre et limites

2.1 Objectif de la mission

L'audit vise à évaluer l'exposition et la robustesse des contrôles de sécurité de l'instance de laboratoire avant une mise en production simulée, notamment les contrôles d'accès, l'exposition de données et la logique métier.

2.2 Périmètre

Cibles	http://localhost:3000 (instance OWASP Juice Shop de laboratoire)
Comptes / rôles fournis	Deux comptes de test utilisés pour valider les contrôles inter-utilisateurs
Mode	Mixte - Black Box + Grey Box
Exclusions	Réseau de l'établissement, postes d'autres étudiants, services Internet tiers, domaines non fournis et toute cible hors instance attribuée.
Tests interdits	DoS, destructif, hors scope, tiers non autorisés

2.3 Limites et réserves

Tests réalisés uniquement sur l'instance de laboratoire observée. Les éléments non confirmés ne sont pas présentés comme vulnérabilités. La qualification CVSS détaillée reste à confirmer lorsque les métriques d'impact ne sont pas suffisamment documentées.

3. Méthodologie et couverture

Approche suivie : cadrage du scope → reconnaissance et cartographie → interception des requêtes avec Burp Suite → formulation d'hypothèses → tests manuels ciblés → validation par comparaison entre comptes → collecte de preuves → rédaction et priorisation.

3.1 Surfaces testées

Surface / fonctionnalité	Testée ?	Résultat	Référence preuve / note
Authentification	Oui	RAS dans les tests documentés	Notes / session de test
Gestion de session	Oui	RAS dans les tests documentés	Notes / session de test
Contrôle d'accès horizontal	Oui	Finding F-03	Annexe C – Preuve F-03
Contrôle d'accès vertical	Oui	Non concluant	Notes de test – contrôle vertical
Endpoints / API	Oui	Findings F-01 / F-02 / F-03	Annexes A, B et C
Entrées utilisateur / injection	Oui	Non concluant sur l'adresse ; manipulation du panier confirmée	Notes / Annexe C

3.2 Tests négatifs et hypothèses infirmées

Tests négatifs / points non concluants : (1) aucune vulnérabilité d'authentification n'a été confirmée ; (2) aucun contrôle d'accès vertical n'a été confirmé comme contournable ; (3) la modification de champs d'adresse a été observée mais n'a pas permis de démontrer un impact de sécurité par elle-même. Ces tests sont conservés pour matérialiser la couverture.

4. Constats détaillés

Dupliquez la fiche ci-dessous pour chaque finding confirmé. Le constat doit pouvoir être reproduit par une autre personne sans explication orale.

F-01 - Exposition d'informations sensibles dans un dépôt accessible

Sévérité	Élevée
CVSS	Version : 4.0 | Score : à confirmer | Vecteur : à confirmer
Priorité de remédiation	P1 immédiat
Complexité de remédiation	Moyenne - suppression des données sensibles, rotation des secrets et vérification de l'historique du dépôt.
Actif / endpoint	Application / lien GitHub → dépôt de données → fichier users.yml
Préconditions	Utilisateur de test ; accès à l'instance locale ; navigation jusqu'au lien GitHub.

Description

L'application expose un accès vers un dépôt GitHub contenant un répertoire de données et un fichier static/users.yml. Les notes d'audit montrent que ce fichier contient des informations relatives au compte administrateur et un mot de passe faible. Le contrôle attendu est l'absence de secrets ou de données d'authentification dans des ressources accessibles à un utilisateur de l'application.

Étapes de reproduction

1. Depuis le menu de l'application, accéder au lien GitHub.
2. Ouvrir le répertoire Data puis la zone static.
3. Ouvrir le fichier users.yml.
4. Constater la présence d'informations relatives au compte administrateur et d'un mot de passe faible.

Preuve

Voir Annexe A : capture du dépôt accessible et de l'arborescence contenant users.yml. Le contenu détaillé n'est pas reproduit afin de ne pas divulguer le secret en clair.

Impact

L'exposition de données d'authentification peut faciliter une compromission de compte, notamment si les identifiants exposés restent valides. L'impact métier potentiel est l'accès non autorisé à des fonctionnalités ou données réservées au compte administrateur.

Remédiation

Supprimer immédiatement les secrets du dépôt public ou accessible depuis l'application, révoquer/changer toute information d'authentification exposée, puis vérifier l'historique Git et mettre en place une gestion dédiée des secrets.

Validation / re-test proposé

Vérifier que users.yml ne contient plus de secrets, qu'aucune ancienne révision accessible ne révèle ces informations et que les anciens identifiants ne permettent plus d'authentification.

F-02 - Accès à un document confidentiel via /ftp

Sévérité	Moyenne
CVSS	Version : 4.0 | Score : à confirmer | Vecteur : à confirmer
Priorité de remédiation	P2 court terme
Complexité de remédiation	Faible - contrôle d'accès et séparation du stockage des documents.
Actif / endpoint	GET /ftp puis /ftp/acquisitions.md
Préconditions	Utilisateur non privilégié ; accès à l'instance de test.

Description

Le répertoire /ftp permet de découvrir et de récupérer un fichier acquisitions.md explicitement présenté comme confidentiel. Le contrôle attendu est qu'un document confidentiel ne soit pas exposé directement par une ressource Web publique sans autorisation.

Étapes de reproduction

1. Dans l'application, accéder à « À propos de nous ».
2. Suivre le lien vers la ressource /ftp.
3. Observer la liste de fichiers puis ouvrir acquisitions.md.
4. Constater que le document est accessible alors qu'il est présenté comme confidentiel.

Preuve

Voir Annexe B : capture du document acquisitions.md portant la mention de confidentialité.

Impact

Un attaquant peut consulter des informations internes ou stratégiques qui ne devraient pas être accessibles à un utilisateur non autorisé. L'impact porte principalement sur la confidentialité.

Remédiation

Déplacer les documents confidentiels hors des répertoires directement servis par le serveur Web et appliquer un contrôle d'autorisation côté serveur avant toute restitution de fichier.

Validation / re-test proposé

Vérifier que /ftp/acquisitions.md renvoie désormais un refus d'accès pour un utilisateur non autorisé et que seuls les rôles prévus peuvent récupérer le document.

F-03 - Modification du panier d'un autre utilisateur

Sévérité	Elevée
CVSS	Version : 4.0 | Score : à confirmer | Vecteur : à confirmer
Priorité de remédiation	P1 immédiat
Complexité de remédiation	Moyenne - correction du contrôle d'autorisation dans la logique métier et tests de régression.
Actif / endpoint	Endpoint de gestion du panier /api/BasketItems
Préconditions	Deux comptes de test distincts ; compte B authentifié ; BasketID=6 appartenant à un autre utilisateur.

Description

L'API accepte un BasketID fourni par le client sans vérifier que le panier appartient à l'utilisateur authentifié. La modification d'un identifiant de panier permet à un utilisateur d'ajouter un produit dans le panier d'un autre compte.

Étapes de reproduction

1. Avec le compte A, relever le BasketID=6 de son panier.
2. Avec le compte B, intercepter une requête d'ajout de produit au panier.
3. Remplacer le BasketID légitime du compte B par BasketID=6.
4. Renvoyer la requête et constater l'ajout du produit dans le panier du compte A.

Preuve

Voir Annexe C : preuve de réussite de la manipulation du panier d'un autre utilisateur.

Impact

Un utilisateur authentifié peut modifier les données de panier d'un autre compte. Cela affecte l'intégrité des données et peut perturber ou manipuler le processus de commande.

Remédiation

Effectuer côté serveur un contrôle systématique liant le panier à l'identité authentifiée avant toute lecture ou écriture. Ne jamais considérer le BasketID fourni par le client comme une preuve d'appartenance.

Validation / re-test proposé

Avec deux comptes, répéter la même manipulation après correction : une requête utilisant le BasketID d'un autre compte doit être refusée et aucune modification ne doit apparaître dans le panier cible.

5. Plan de remédiation

Priorité	Action	Findings liés	Complexité	Résultat attendu
P1	Vérifier l'appartenance du panier à l'utilisateur authentifié avant toute modification.	F-03	M	Impossible de modifier le panier d'un autre compte.
P1	Supprimer les secrets des ressources exposées, changer les identifiants concernés et auditer l'historique Git.	F-01	M	Aucune donnée d'authentification exploitable dans le dépôt.
P2	Retirer les documents confidentiels des répertoires Web publics et ajouter une autorisation serveur.	F-02	F	Les fichiers confidentiels ne sont plus accessibles sans droit.

6. Conclusion

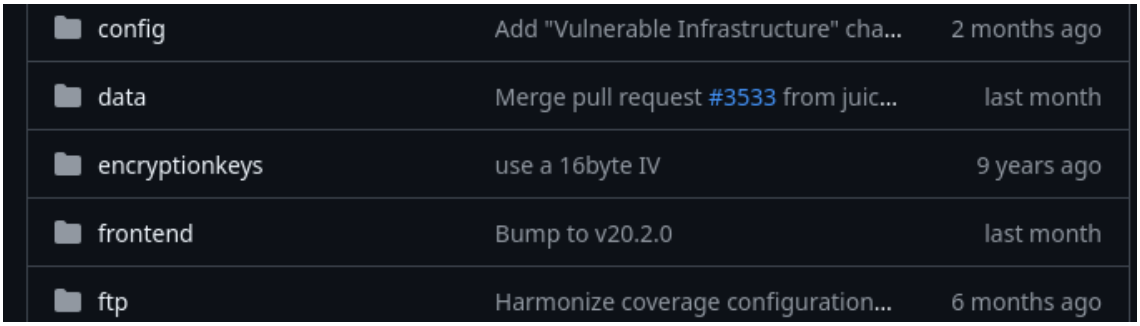
L'audit met en évidence un niveau de sécurité global « à renforcer », en raison de faiblesses de contrôle d'accès et d'exposition de ressources. Le point le plus prioritaire concerne la possibilité de modifier le panier d'un autre utilisateur, ce qui démontre un défaut de contrôle d'autorisation côté serveur.

Les autres constats portent sur l'exposition d'informations sensibles dans un dépôt accessible et sur l'accès à un document confidentiel via /ftp. Les limitations principales concernent le temps de l'exercice et l'absence de validation complète de certains impacts. Un re-test est recommandé après correction des trois findings prioritaires.

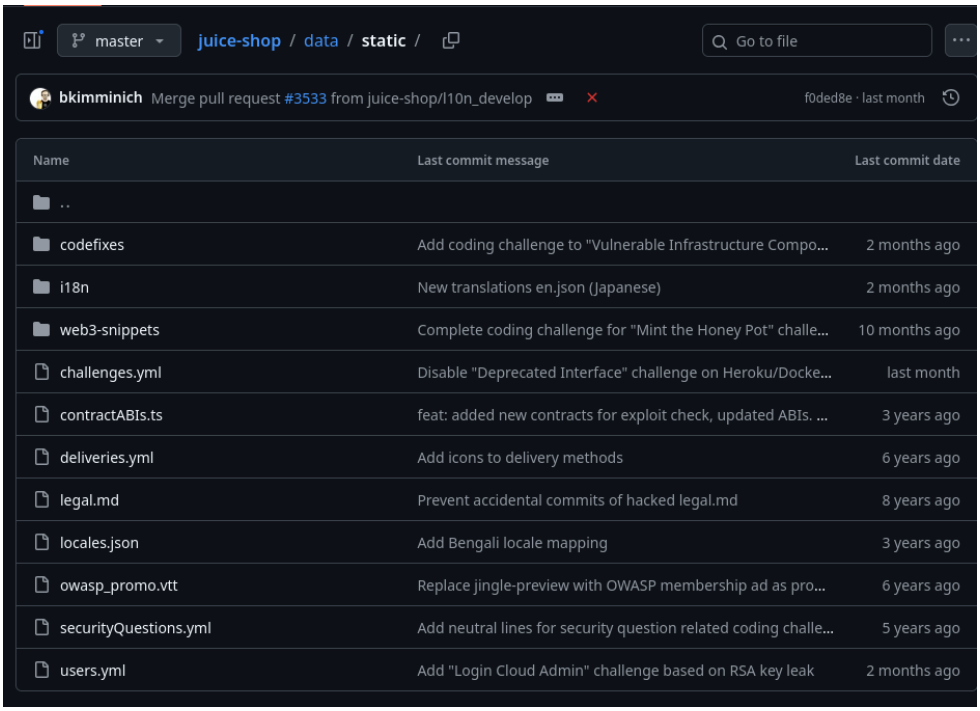
7. Annexes

- Outils utilisés : navigateur Web, Burp Suite (interception et modification des requêtes), navigation dans le dépôt GitHub lié à l'application.
- Journal de tests : cartographie de l'application, vérifications d'authentification/session, tests d'autorisation horizontale et verticale, tests d'endpoints API, tests de manipulation du panier et tests de validation des champs d'adresse.
- Preuves : seules les captures nécessaires sont reproduites ci-dessous ; aucun mot de passe, token ou secret n'est affiché dans le rapport.
- Références : OWASP Web Security Testing Guide (WSTG), OWASP Juice Shop, CVSS v4.0 (FIRST).

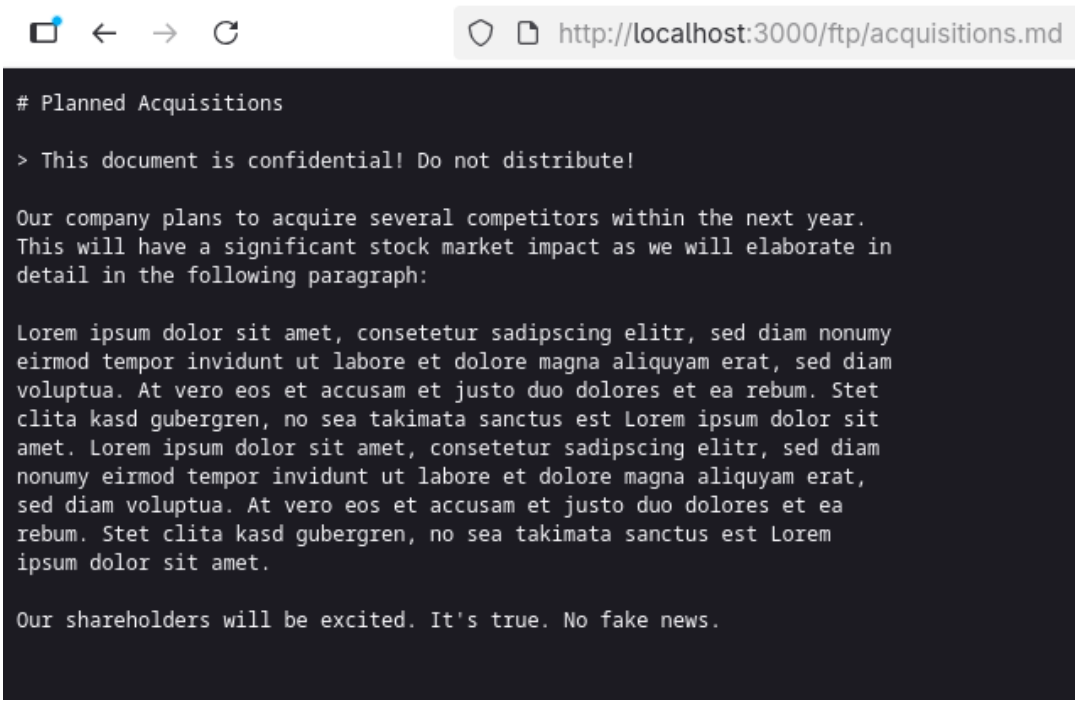
Checklist avant remise



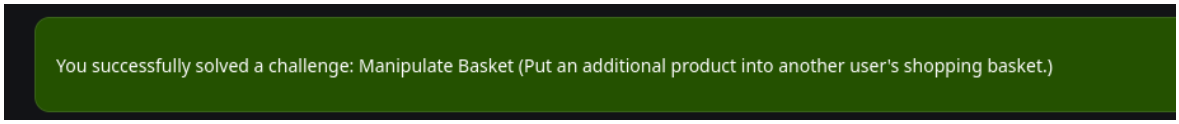
Annexe A — Dépôt lié depuis l'application : présence du répertoire data.



Annexe A — Arborescence du dépôt : présence du fichier users.yml.



Annexe B — Document acquisitions.md accessible malgré la mention de confidentialité.



Annexe C — Preuve de réussite de la manipulation du panier d'un autre utilisateur.



Annexe C — État du panier après la manipulation.

- ☒ Chaque finding a un titre compréhensible et un actif concerné.
- ☒ Les preuves sont lisibles et ne contiennent pas de secrets inutiles.
- ☒ Les étapes de reproduction sont complètes.
- ☒ Le CVSS comporte sa version et, si possible, son vecteur.
- ☒ La remédiation traite la cause racine.

- ☒ La complexité de remédiation est justifiée indépendamment de la sévérité.
- ☒ Le résumé exécutif présente les problématiques générales et les priorités.
- ☒ Les limitations et zones non couvertes sont mentionnées.
- ☐ Le rapport a été relu par un autre membre du groupe.